

Rapport — Étape 1 : correction des failles de sécurité

Application Fun Kids Animation · Corrections, vérifications et procédure de test · 24 septembre 2026

Élément	Détail
Étape du plan d'action	Étape 1 — Corriger les failles critiques (audit du 24/09)
Branche / commit	nassim · commit e8ed796 « fix: correction des failles de securite critiques (etape 1) »
Fichiers modifiés	users/urls.py, availability/views.py, payments/views.py, web/views.py, reviews/views.py + tests associés
Base de données	Aucune modification — ni migration, ni changement de structure
Tests automatiques	79 tests : tous OK (56 existants + 23 nouveaux)
Résultat global	Étape 1 terminée

1. Objectif

Supprimer les failles de sécurité relevées par l'audit avant toute démonstration : empêcher la connexion à un compte sans mot de passe, protéger les données d'indisponibilité, garantir l'authenticité des notifications de paiement et cloisonner les données entre clients. Aucune fonctionnalité existante ne devait être dégradée.

2. Récapitulatif des corrections

#	Faillle corrigée	Gravité	Statut
1	Connexion à n'importe quel compte via l'URL de retour Google	Critique	✓ Réalisé
2	API des indisponibilités modifiable sans connexion	Critique	✓ Réalisé
3	Webhook Stripe accepté sans signature	Haute	✓ Réalisé
4	Pages de retour de paiement sans contrôle du titulaire	Moyenne	✓ Réalisé
5	Avis modifiables par tout utilisateur connecté	Moyenne	✓ Réalisé

3. Description détaillée

3.1 Connexion Google (critique)

Avant

/auth/google-callback/?email=... ouvrait directement la session du compte indiqué, y compris administrateur, sans mot de passe ni vérification.

Après

L'adresse e-mail provient désormais **uniquement** de l'identité vérifiée par Google (échange du code d'autorisation, contrôle de email_verified). Les paramètres de l'URL sont ignorés. Le sélecteur de compte simulé (démonstration) n'est plus actif par défaut : il nécessite le mode DEBUG et l'activation explicite GOOGLE_LOGIN_SIMULATION=True dans le .env, n'accepte que l'envoi du formulaire, et refuse toujours les comptes administrateur et animateur. Sans configuration Google, le bouton renvoie vers la page de connexion avec un message clair.

Fichier : users/urls.py

3.2 API des indisponibilités (critique)

Avant

/api/availability/ était en accès libre : un visiteur anonyme pouvait créer, modifier ou supprimer les indisponibilités des animateurs, et donc fausser les créneaux proposés.

Après

Lecture toujours publique (liste, vérification de créneau, créneaux du jour, animateurs disponibles), nécessaire au tunnel de réservation. Création, modification et suppression réservées à l'administration. Les animateurs continuent de gérer leurs indisponibilités depuis leur espace personnel (inchangé).

Fichier : availability/views.py

3.3 Webhook Stripe (haute)

Avant

Sans STRIPE_WEBHOOK_SECRET, le webhook traitait tout événement reçu : un faux message « paiement réussi » suffisait à confirmer une réservation.

Après

Tout événement est désormais vérifié par sa signature Stripe. Sans secret valide, ou avec une signature fausse, la requête est refusée (HTTP 400) et journalisée. La confirmation du paiement par la page de succès, qui interroge directement Stripe, fonctionne toujours sans webhook.

Fichier : payments/views.py

3.4 Pages de retour de paiement (moyenne)

Avant

Les pages de succès et d'annulation affichaient le détail d'une réservation (adresse, enfant, montant) à partir de son seul numéro, sans vérifier l'utilisateur.

Après

Le détail n'est affiché qu'au titulaire de la réservation ou à l'administration. La mise à jour du statut après un paiement vérifié par Stripe reste effectuée dans tous les cas.

Fichier : web/views.py

3.5 Avis clients (moyenne)

Avant

Tout utilisateur connecté pouvait modifier ou supprimer n'importe quel avis, et en créer sur la réservation d'un autre client.

Après

Création et modification limitées au titulaire de la réservation (ou à l'administration). La lecture des avis reste publique.

Fichier : reviews/views.py

4. Vérifications effectuées

4.1 Tests automatiques

Suite	Nouveaux tests	Résultat
users/tests.py	9 — connexion Google : URL, formulaire, simulation, comptes privilégiés, identité vérifiée	✓ Réalisé
availability/tests.py	4 — anonyme, client, administrateur, lecture publique	✓ Réalisé
payments/tests.py	6 — webhook sans secret / signature fausse, pages de retour (titulaire, autre, anonyme)	✓ Réalisé

Suite	Nouveaux tests	Résultat
reviews/tests.py	4 — autre utilisateur, réservation d'autrui, titulaire, lecture publique	✓ Réalisé
Suite complète	79 tests (dont les 56 existants, adaptés pour le webhook signé)	✓ Réalisé

Contrôles complémentaires : manage.py check sans erreur, makemigrations --check : aucune migration.

4.2 Rejeu des attaques sur le serveur réel

Serveur de vérification lancé en local sur **http://127.0.0.1:8011** (base de données du projet), puis arrêté après les essais.

Essai	Avant	Après	Statut
GET /auth/google-callback/?email=animateur@...	302, session ouverte	302 vers /auth/login/, aucune session	✓ Réalisé
GET /auth/google-login/ (sans configuration)	faux sélecteur Google	302 vers /auth/login/ + message	✓ Réalisé
POST anonyme /api/availability/	201 (création)	403	✓ Réalisé
DELETE anonyme /api/availability/1/	autorisé	403	✓ Réalisé
GET /api/availability/slots/	200	200 (inchangé)	✓ Réalisé
POST webhook non signé « paiement réussi »	200, réservation confirmée	400, rien de modifié	✓ Réalisé
Page /payment-cancelled/?booking_id=1 anonyme	détail affiché	détail masqué	✓ Réalisé

4.3 Non-régression

Parcours	Résultat	Statut
Pages publiques : /, /nos-surprises/, /pricing/, /gallery/, /about/, /contact/	HTTP 200	✓ Réalisé
Connexion / inscription : /auth/login/, /auth/signup/, /admin/login/	HTTP 200	✓ Réalisé
Connexion par e-mail + mot de passe (animateur de démonstration)	302 vers l'accueil, tableau de bord 200	✓ Réalisé
API publiques : /api/services/, /api/reviews/	HTTP 200	✓ Réalisé

5. Comment tester soi-même

5.1 Tests automatiques (depuis la racine du projet)

```
venv/bin/python manage.py test
```

Résultat attendu : « Ran 79 tests ... OK ». Pour ne lancer que les tests de sécurité :

```
venv/bin/python manage.py test users availability payments reviews
```

5.2 Tests manuels (serveur lancé sur le port 8010)

```
venv/bin/python manage.py runserver 0.0.0.0:8010
```

- Ouvrir **http://127.0.0.1:8010/auth/google-callback/?email=admin@funkidz.fr** : on doit revenir sur la page de connexion, sans être connecté.
- Cliquer sur « Continuer avec Google » (page de connexion) : message « La connexion avec Google n'est pas disponible pour le moment. »
- Se connecter normalement avec e-mail + mot de passe : fonctionne comme avant.

- Dans un terminal : `curl -X DELETE http://127.0.0.1:8010/api/availability/1/` → réponse 403.
- Réserver puis payer avec la carte test 4242 4242 4242 4242 : la réservation passe en « Confirmée » (le webhook n'est pas nécessaire en local).

6. Configuration (.env) et points d'attention

Variable	Rôle	Valeur par défaut
GOOGLE_CLIENT_ID / GOOGLE_CLIENT_SECRET	Connexion Google réelle (les deux sont requis)	vide → bouton Google indisponible
GOOGLE_LOGIN_SIMULATION	Sélecteur Google simulé pour une démo locale (DEBUG uniquement, comptes clients)	désactivé
STRIPE_WEBHOOK_SECRET	Obligatoire pour que le webhook Stripe soit accepté (production)	vide → webhook refusé

- Changement de comportement volontaire : le faux sélecteur « Choisir un compte Google » n'apparaît plus par défaut. Pour le réafficher en démonstration locale : `GOOGLE_LOGIN_SIMULATION=True` dans le `.env`.
- Ces variables ne sont pas encore décrites dans `.env.example` : ce fichier contient une modification en cours non committée (`ALLOWED_HOSTS`), laissée intacte. À compléter lors du prochain commit de configuration.
- Aucune clé ni secret n'a été ajouté au dépôt.

7. Suite du plan d'action

Étape	Contenu	Statut
1	Faibles de sécurité critiques	✓ Réalisé
2	Comptes et connexion multi-clients (e-mails en minuscules, comptes de test)	À faire
3	Parcours de paiement Stripe (Link, échec, annulation)	À faire
4	Brevo et e-mails de bout en bout	À faire
5 à 10	Créneaux, administration, calendrier, livraison du 29/09, soutenance	À faire